

ShieldAI

The Virtual CISO Platform

Affordable today. A managed-security platform at scale.

BUSINESS PLAN

Confidential · 2026

Prepared by Xandu Limited, LLC

Contents

1. Executive Summary

Key Highlights

2. The Problem & Market Opportunity

2.1 The SMB Security Gap

2.2 Market Size

2.3 Market Sizing (Bottom-Up)

2.4 Why Now

3. Product & Platform

3.1 What the Customer Gets Today

3.2 The Scoring Engine — Our Core IP

3.3 The Role of AI

4. Strategy: Wedge to Platform

4.1 The Wedge — Self-Serve & Growth Tiers

4.2 The Expansion — Managed vCISO Programs

4.3 The Platform — The Analyst Console (Live)

5. Business Model

5.1 Revenue Streams

5.2 Pricing Tiers

5.3 Unit Economics — The Scalability Engine

6. Financial Projections

7. Competitive Landscape & Defensibility

7.1 The Landscape

7.2 Why We Win

8. Product Roadmap

What's Live Today

What This Raise Funds

9. Team & Execution

10. The Ask & Use of Funds

11. Risk Analysis & Mitigation

12. Summary

1. Executive Summary

“A full-time CISO costs \$200,000–\$400,000 a year. Nearly half of small businesses have no security budget at all — yet their insurers, customers, and regulators now require a real security program. ShieldAI closes that gap.”

ShieldAI is a virtual Chief Information Security Officer (vCISO) platform for small and mid-sized businesses (SMBs). It delivers a complete, continuously-managed security program — risk scoring, written policies, a prioritized roadmap, compliance mapping, real threat intelligence, awareness training, and executive reporting — at a price a small business can actually afford.

ShieldAI is not a prototype or a slide deck: the full platform described in this plan is live in production today, including the managed-services analyst console, the AI advisory co-pilot, and Stripe-billed subscriptions across five tiers. This raise does not fund building the platform — it funds staffing and go-to-market for the managed-services engine that platform already runs.

ShieldAI is powered by frontier AI — routed across multiple providers by task — for analysis and content generation, but our defensibility does not rest on the AI itself. It rests on three things: a proprietary, deterministic security-scoring engine built on the NIST Cybersecurity Framework that produces explainable, auditor- and insurer-trustworthy results; a human-in-the-loop model in which qualified engineers review and approve work before it reaches the client; and the proprietary assessment data and client relationships that compound over time.

Key Highlights

Metric	Detail
Target market	U.S. SMBs with employees, prioritizing regulated and insured segments
Core category	Virtual CISO (vCISO) — ~\$2B+ today, growing 12–15%+ annually
Demand driver	Cyber-insurance, customer security requirements, and regulation forcing SMBs to act
Model	Wedge: Free/Starter self-serve → Expand: Growth/Guided → Managed vCISO
Differentiation	Deterministic NIST/CIS scoring engine + human-in-the-loop + live analyst platform
Stage	Live in production: assessment & scoring, 12 compliance frameworks, real CVE/dark-web threat intel, read-only monitoring agents, AI advisory co-pilot with tool-use, 5-report audit/insurance/legal suite, evidence tracking, training delivery, white-label branding, Stripe billing across 5 tiers
Next milestone	Hire the first cybersecurity engineers onto the live analyst console; convert early access-code users into paying managed clients

This plan reflects ShieldAI's current direction: the platform — self-serve product and managed-services console alike — is built and functioning. This raise funds people and distribution, not further core platform construction.

2. The Problem & Market Opportunity

2.1 The SMB Security Gap

Small businesses face the same threat landscape as enterprises — ransomware, phishing, business email compromise, supply-chain attacks — but lack the budget, expertise, or time to respond. They are caught in a structural bind: too big to ignore security, too small to afford a dedicated leader. A full-time CISO costs \$200,000–\$400,000 or more per year, while the foundational tools and expertise cost roughly the same whether a business has 10 employees or 100 — so the per-employee burden falls hardest on the smallest firms.

The data shows how exposed this segment is:

- 47% of businesses with fewer than 50 employees have no cybersecurity budget at all (StrongDM / CrowdStrike, 2025).
- 51% have no security measures in place; one-third rely on free, consumer-grade tools.
- Only 34% have a formal incident response plan (Guardz, 2025).
- Only ~13% conduct proactive security audits, and only ~1 in 5 performs annual penetration testing.
- Small businesses represent roughly 43% of all cyberattacks, and SMB incident rates rose ~47% year over year.

The cost of inaction is severe and quantifiable: IBM data shows a tested incident-response plan reduces breach cost by approximately \$232,000, and prevention investment returns consistently exceed 7x. A foundational program costing \$5,000–\$15,000 a year would save hundreds of thousands in the event of a breach — yet the businesses that spend nothing are the ones that pay the most.

2.2 Market Size

ShieldAI sits in the virtual CISO category, inside the broader SMB cybersecurity market.

Market	Size / Estimate	Source
U.S. small businesses	36.2M total; ~5.8M with employees	SBA Office of Advocacy, 2025
Global SMB cybersecurity spend	~\$109B by 2026, ~10% CAGR	Analysys Mason
Virtual CISO market (global)	~\$2B+ in 2025, 12–15%+ CAGR	Composite (multiple research firms)
U.S. cyber-insurance market	~\$3.9B (2025), ~22% CAGR	Market Research Future

vCISO market estimates vary by research firm — from roughly \$1.06B to \$2.89B for 2024–25, with forecasts ranging from \$1.5B to \$12B by the early 2030s — because firms scope the category differently. Every credible source agrees on the direction: double-digit annual growth driven by escalating threats, a 3.4-million-person global cybersecurity talent shortage, and tightening compliance.

2.3 Market Sizing (Bottom-Up)

- TAM: The global vCISO category, ~\$2B+ and growing 12–15%+ per year — the market we directly serve.
- SAM: ~5.8M U.S. employer businesses, narrowed to regulated/insured/supply-chain segments (a conservative 10–20% → roughly 600K–1.2M businesses). At a blended program value in the low thousands per year, this is a multi-billion-dollar serviceable market.

- SOM: A modest, credible early capture — e.g., 1% of a 600K-business SAM at a few thousand dollars per year per client — represents a business on the order of \$20M+ in annual recurring revenue, reached over a 3–5 year horizon via the self-serve-to-managed motion.

Final ARPU, pricing tiers, and segment definitions reflect the live product's five-tier ladder (Section 5.2); the SAM/SOM figures above illustrate the framework, not committed numbers.

2.4 Why Now

The decisive shift is that demand is no longer driven by whether small businesses care about security, it is being forced on them by three external pressures converging at once:

- Cyber-insurance as gatekeeper: Insurers now require proof of specific controls (MFA, incident response, etc.) before issuing or renewing policies. 63% of SMBs saw premiums rise 200%+ in 2025, and businesses under \$25M in revenue filed 64% of all cyber-insurance claims — so insurers are tightening precisely on our target segment.
- Customer-driven requirements: Larger customers increasingly push security questionnaires and insurance requirements down to their small vendors. Without a demonstrable program, small businesses lose contracts.
- Expanding regulation: HIPAA, CMMC (defense supply chain), the FTC Safeguards Rule, and state privacy laws now carry real penalties — reaching deep into the small-business tier.

On the supply side, AI has only recently become capable enough to deliver expert-level security analysis and documentation at a cost that makes serving the small-business segment economically viable. The need and the means have arrived at the same moment — and ShieldAI has already built the platform that meets it.

3. Product & Platform

3.1 What the Customer Gets Today

From a short, structured assessment, ShieldAI produces — and continuously runs — a complete security program through a unified dashboard. Every item below is live in production, not planned:

- Security assessment: a conversational intake plus a 35-question NIST/CIS-mapped checklist — 13 that drive the posture score, 22 evidence-only questions that unlock deeper compliance mapping.
- Deterministic risk score: an explainable NIST CSF or CIS Controls v8.1 posture score (client's choice of lens, or both) with a per-function breakdown.
- 12 compliance frameworks, control-level mapped: NIST CSF, CIS Controls v8.1, HIPAA Security Rule, SOC 2, PCI-DSS, ISO 27001, NIST 800-171, CMMC 2.0, NIST 800-53, FTC Safeguards, and State Privacy are control-mapped with real citations; GDPR is AI-assisted gap analysis. Per-framework scoping questionnaires (e.g., PCI SAQ type, SOC 2 trust-services categories) sharpen exactly which controls apply.
- Real threat intelligence: live CVE matching against a client's actual reported software via the NVD feed, plus breach exposure from Have I Been Pwned — gated on verified domain ownership so we never query a domain nobody proved they control. No fabricated data, anywhere in the product.
- Read-only monitoring agents (Windows, Linux, macOS): report live posture and software inventory for CVE matching. Permanently read-only — no inbound command channel exists, by design.
- Agent-vs-questionnaire corroboration: where the agent's measurement and the client's answer disagree, the conflict is surfaced to a human to resolve — never auto-overridden in either direction.
- Prioritized remediation: a task board ranking every open gap by the exact posture-score gain fixing it would produce; completing a task re-scores the client automatically.
- Evidence & audit readiness: clients attach proof to completed work and see a live audit-coverage score — the evidence insurers and auditors actually ask for.
- Custom framework support: for a client with obligations beyond the standard catalogue, an admin defines the framework's own controls, tracked per-control with the same agent-or-self-reported honesty rules, plus on-demand AI remediation grounded in that specific control.
- Five report types — status and update (client self-serve) plus compliance, insurance, and legal (staff-prepared and delivered) — as branded, Word-ready documents.
- Professional policy library, incident response workflows, a recommended tool stack, a full awareness-training curriculum, and a board-ready executive report.
- Standalone training delivery: tokenized learner links (no login required), quarterly scheduling, completion tracking, and fleet-wide reporting for the employees actually completing training.
- White-label branding for MSPs and analysts reselling the platform under their own brand.

3.2 The Scoring Engine — Our Core IP

ShieldAI's differentiator is a deterministic risk-scoring engine built on the NIST Cybersecurity Framework (with a CIS Controls v8.1 lens as an alternative or companion view). Unlike an AI that “guesses” a number, the engine computes a posture score across the five NIST functions — Identify, Protect, Detect, Respond, and Recover — each weighted and scored from the structured assessment. The same inputs always produce the same score, and every point traces to a specific control.

This matters commercially: an insurer, auditor, or enterprise customer can trust an explainable, repeatable score in a way they would never trust an opaque AI output. The scoring methodology is proprietary and improves as our assessment dataset grows.

3.3 The Role of AI

Frontier AI powers the analytical and generative work, routed to the provider best suited to each task — with a real, automatic fallback so the platform keeps working if any one provider is unavailable. The architecture is model-flexible by design: no single vendor is a dependency, and additional models can be incorporated where they add value. Crucially, the AI accelerates expert work rather than replacing expert judgment — every client-facing deliverable is either deterministically computed or reviewed by a human — which is central to both our quality bar and our liability posture.

4. Strategy: Wedge to Platform

4.1 The Wedge — Self-Serve & Growth Tiers

The entry tiers are affordable and self-serve. A business completes an assessment, receives a real posture score and a complete program, and can build policies, track compliance, and (from Growth up) pull real threat intelligence — immediate, tangible value at a fraction of the cost of a consultant. This wedge gets businesses in the door cheaply, proves the model, and builds the assessment dataset that strengthens our scoring engine.

4.2 The Expansion — Managed vCISO Programs

As clients grow or face greater compliance demands, they graduate to Guided or Managed plans in which a ShieldAI cybersecurity engineer reviews, and ultimately runs, their security program on an ongoing basis. This is higher-value, higher-retention recurring revenue, and it is where the human-in-the-loop model delivers both quality and trust.

4.3 The Platform — The Analyst Console (Live)

The engine of scale is the analyst console: a command center where each engineer manages a portfolio of client businesses, enforced with strict per-client isolation — an analyst can only ever reach clients explicitly assigned to them. From a single interface an engineer monitors every client's posture and trend over time, sees findings from agents deployed in client networks, and reviews and approves AI-drafted work before it reaches the client. An integrated AI co-pilot — “ShieldAI Mastermind” — has genuine on-demand tool-use across the client portfolio: it can look up a specific client's compliance status, CVE exposure, task backlog, or agent-vs-questionnaire disputes on request, not just recite a static snapshot.

This console is live in production today, not a mockup — the primary objective of this raise is staffing it with engineers, not building it.

The AI does the first 80%. The engineer adds the high-value 20% — judgment, accountability, and the client relationship. That blend is our margin and our quality bar.

5. Business Model

5.1 Revenue Streams

- Self-serve subscriptions — Free, Starter, and Growth tiers; low-cost, high-volume entry and mid-market revenue.
- Managed vCISO plans — Guided and Managed tiers; engineer-reviewed or engineer-run programs, the primary long-term recurring-revenue engine.
- Add-ons — the standalone training-delivery product (\$40/month for Starter; bundled at Growth and above).
- Channel / partnerships — referrals from cyber-insurers, MSPs, and professional-services firms whose clients are required to demonstrate controls (a natural low-CAC path).

5.2 Pricing Tiers

Pricing is set to undercut traditional human-only vCISO retainers — which typically run \$2,500–\$11,600/month for SMB clients — while remaining more complete than automated-only tools. Because AI performs the heavy lifting, ShieldAI can price competitively for real SMB budgets and still hold healthy margins. Five tiers are live today, enforced backend-first (not just a UI gate):

Tier	Price / month	What it includes
Free	\$0	Security assessment and NIST/CIS posture score — the zero-friction entry point
Starter	\$159	Multiple assessments, full program builder, up to 6 policies, AI-recommended training plan, 5 monitored endpoints; training delivery available as a \$40/mo add-on
Growth	\$349	Everything in Starter, plus real CVE/dark-web threat intelligence, bundled training delivery, up to 10 policies, 25 endpoints, full downloads/exports
Guided	\$699	Everything in Growth, plus periodic engineer review, compliance tracking, scheduled check-ins, up to 100 endpoints
Managed vCISO	\$1,950	A ShieldAI engineer runs the security program end-to-end — unlimited endpoints, full agent access, client-facing Mastermind Q&A — still below human-only competitors

The ladder is designed for land-and-expand: a business enters free, and grows into paid and eventually managed plans as trust builds and compliance demands increase. The managed tier deliberately sits at or below the bottom of the traditional retainer range — “a fractional CISO at a fraction of the cost.”

5.3 Unit Economics — The Scalability Engine

The defining economics are at the managed tier, where the analyst console and AI co-pilot let a single cybersecurity engineer manage roughly 25 clients at a high-touch service level. The figures below reflect a hand-verified unit-economics model, not planning shorthand.

Metric	Value
Managed price	\$1,950 / month
Clients per engineer	~25 (enabled by the AI-amplified console)

Revenue per engineer (managed)	~\$585,000 / year
Fully loaded engineer cost	~\$140,000 / year
AI cost per client	~\$0.28 / client / month (measured, not estimated)
Managed-tier gross margin	~75%
Blended gross margin (all tiers)	~60%

A correction from earlier drafts: measured AI cost is ~\$0.28 per client per month — far below the ~\$15 previously assumed — so AI cost is not a meaningful constraint on this model. The ~75% margin applies to the managed tier specifically; blended across the self-serve tiers, gross margin is ~60%. The binding constraint on the model is churn, not price or AI cost. Self-serve and Growth tiers add high-margin, low-touch revenue on top of the managed engine.

This is the crux of the investment thesis: revenue scales with the client book while engineer headcount grows far more slowly, because the software does the heavy lifting. Margins improve further as the assessment dataset and automation mature.

6. Financial Projections

The following is an illustrative three-year ramp based on the pricing and unit economics above. It assumes a deliberate mix shift toward Growth/Guided/Managed clients as the platform matures, with engineer headcount scaling to support the managed book at ~25 clients each — managed clients, not total clients, drive engineer hiring.

	Year 1	Year 2	Year 3
Free / Starter clients	180	550	1,300
Growth clients	40	150	420
Guided clients	30	120	350
Managed clients	20	95	300
Total paying clients	270	915	2,370
Security engineers	1	5	23
Annual Recurring Revenue	~\$1.0M	~\$4.0M	~\$11M
Blended gross margin	~55%	~58%	~60%

These figures illustrate the model's shape and the operating leverage of the engineer-plus-AI structure; they are planning estimates, not commitments, and will be refined with real acquisition and retention data. Year-3 headcount (~23 engineers) reflects the corrected model: managed clients — not total clients — drive engineer hiring, and ARR grows roughly 4x faster than that headcount — the signature of a platform rather than a consultancy.

7. Competitive Landscape & Defensibility

7.1 The Landscape

Category	Examples	Limitation	ShieldAI Edge
Traditional vCISO / consultancies	Fractional CISO, FRSecure, Kroll	Human-only; expensive; priced for mid-market+	AI does the heavy lifting — we serve the small end profitably
AI-native vCISO platforms	Cynomi, RealCISO, Trava	Cynomi in particular sells to MSPs, not directly to SMBs — the real competitive set to watch	Deterministic scoring IP; direct-to-SMB + managed hybrid; live agent telemetry
GRC / scoring tools	SecurityScorecard, CyberSaint	Scoring or compliance only; not a full program	Complete program + human-managed delivery
MSPs / DIY tools	Managed IT add-ons, templates	Tools without strategy or CISO-level judgment	We deliver the CISO function, not just tooling

Cynomi's own guidance advises MSP customers not to price under \$1,500/month — leaving the sub-\$1,500 direct-to-SMB segment ShieldAI targets structurally uncontested by the category's best-known player.

7.2 Why We Win

- Proprietary scoring methodology: explainable, repeatable, and trusted by insurers and auditors — not an opaque AI guess.
- Human-in-the-loop: expert review makes output trustworthy enough to sell and materially limits liability.
- Compounding data and relationships: every assessment and managed client makes the system smarter and stickier.
- A real, monetizable product today: full program generation, 12 compliance frameworks, real threat intelligence, live billing, a read-only monitoring agent, and a live analyst console — not slideware.
- The AI is the commodity; the system around it — methodology, workflow, engineers, data — is the moat. A well-funded competitor cannot trivially replicate the whole system.

8. Product Roadmap

What's Live Today

Every item below is in production now — there is no separate build phase left to fund on the core platform:

- Conversational intake, structured NIST/CIS assessment, and deterministic posture scoring.
- Full AI-generated security program: roadmap, policies (Word export), 12-framework compliance mapping, incident workflows, training curriculum, executive report.
- Real CVE/dark-web threat intelligence, read-only monitoring agents (Windows/Linux/macOS), and agent-vs-questionnaire corroboration.
- Remediation task board, evidence & audit-readiness tracking, and custom-framework support for clients with obligations beyond the standard catalogue.
- Five report types (status, update, compliance, insurance, legal) as branded, client-deliverable documents.
- Standalone training delivery (tokenized learner links, quarterly scheduling, completion tracking) and white-label branding for MSPs.
- The full analyst console with strict client isolation, and ShieldAI Mastermind — an AI co-pilot with genuine on-demand tool-use across the client portfolio for admins and analysts, plus a tier-scoped client-facing Q&A.
- Five-tier subscriptions (Free/Starter/Growth/Guided/Managed) with backend-enforced limits, live Stripe checkout, billing portal, and webhook-driven tier and add-on changes.

What This Raise Funds

- Hiring and onboarding the first cohort of cybersecurity engineers to run managed client programs through the already-live analyst console.
- Go-to-market: paid acquisition, and channel partnerships with cyber-insurers, MSPs, and professional-services firms for low-CAC distribution.
- SOC 2 readiness for ShieldAI itself — formalizing the controls and evidence a managed-security vendor is expected to demonstrate.
- Continued platform depth: expanding agent telemetry into continuous automated alerting, and deepening framework coverage as client demand dictates.

This is a meaningful reframing from earlier plans: the platform is the proof point, not the ask. The technical risk is retired; this raise buys delivery capacity and distribution.

9. Team & Execution

ShieldAI is founded and built by Derrick Brooks, CEO of Xandu Limited, LLC. A former U.S. Navy Lieutenant Commander with over 20 years in high-stakes risk management, compliance, and IT infrastructure, Derrick has built enterprise security programs from the ground up, administered budgets exceeding \$200,000, and led cross-functional teams of up to 195 personnel — consistently delivering measurable results, including attack-surface reductions of up to 80% through Zero Trust architecture, Azure cloud migration, and automated vulnerability management.

Critically for a security founder, Derrick is not only a strategist but a hands-on practitioner. He has conducted penetration testing across enterprise web applications, cloud infrastructure, and connected-device APIs, uncovering and remediating tens of thousands of vulnerabilities for organizations including a major automotive manufacturer. This offensive fluency, paired with deep command of the compliance frameworks that drive buying decisions — NIST, RMF, CMMC, ISO 27001, and FedRAMP — means he understands both what the product must do technically and why customers will pay for it.

Derrick holds the CISSP, CISM, and CompTIA Security+ certifications, a double M.S. in Cybersecurity from National University, and an MBA in IT Management from Southern New Hampshire University. He is currently pursuing a doctorate in Cybersecurity at Westcliff University, reinforcing frontline experience with ongoing academic rigor.

The product itself is already built and functioning — assessment, scoring, 12-framework compliance, threat intelligence, monitoring agents, the analyst console, AI advisory tooling, reporting, and live billing — demonstrating execution capability and meaningfully de-risking the technical plan. The immediate organizational priority funded by this raise is hiring the first cybersecurity engineers — the people who run managed client programs through the analyst console — alongside continued product refinement.

Because the platform model amplifies each engineer with AI, the team can stay lean relative to the size of the client book it supports. Qualified engineering talent is the key early hire, given that the managed offering depends on credible, accountable human expertise reviewing and standing behind every deliverable.

10. The Ask & Use of Funds

ShieldAI is raising \$900,000 in seed funding to staff and go to market with a platform that is already built — not to build it.

Use of Funds	Amount	%
First security engineers (4–6 hires) to run managed client programs	\$380,000	42%
Go-to-market & channel partnerships (insurers, MSPs, paid acquisition)	\$260,000	29%
Continued platform depth (agent telemetry, expanded framework coverage)	\$140,000	16%
Operations, SOC 2 readiness, legal & compliance	\$90,000	10%
Working capital reserve	\$30,000	3%

This capital takes ShieldAI to Series A readiness by approximately Month 18: a fully staffed managed-services desk running on the live platform, an ARR annualized run-rate on the order of \$3M at that point (versus the ~\$1.0M booked in Year 1 — run-rate, not cumulative bookings), and proven managed-tier retention and unit economics.

“A full-time CISO costs a quarter-million dollars a year. ShieldAI delivers that protection for the price of a subscription — and the platform lets a handful of our engineers protect thousands of businesses.”

11. Risk Analysis & Mitigation

Risk	Mitigation
AI output accuracy / hallucination	Deterministic scoring engine for the trust-critical number; human engineer reviews and approves all client-facing deliverables before release.
Liability if a managed client is breached	Human-in-the-loop accountability; clear scope and terms on the self-serve tier; appropriate professional and cyber insurance; SOC 2 posture underway.
Well-funded competitor (e.g., an AI-native vCISO)	Differentiate on proprietary scoring methodology, the managed services + platform model, and accumulated data and relationships rather than the AI alone.
AI API cost or terms change	Model-flexible architecture with automatic fallback across providers; proprietary logic and scoring sit above any single provider.
Customer churn (“security feels done”)	Managed plans and continuous monitoring make the program perpetually valuable; compliance cycles and reporting anchor retention.
Scaling human expertise	The analyst console + AI co-pilot are live and designed precisely so each engineer manages many clients without linear headcount growth.

12. Summary

ShieldAI addresses a large, underserved, and — critically — a forced-demand market: tens of millions of small businesses that now must demonstrate a real security program but cannot afford to staff one. We enter with an affordable, working self-serve product and expand into high-value managed programs delivered by cybersecurity engineers who are amplified by our software and AI co-pilot.

Our defensibility is a system, not a feature: a proprietary, explainable NIST/CIS scoring engine; a human-in-the-loop model that makes our output trustworthy enough to sell; and the data and relationships that compound with every client. The product — including the managed-services analyst console — is already built and live. This fundraise funds the people and distribution that turn a working platform into a scaled business.